CSC 163: Computing, Ethics, and Society

Data Privacy:
Methods, Limits, and the Privacy Report

ABET SO4, performance indicator 4c

Roadmap

1. **Why privacy matters** and what the law expects
2. **Threats to personal data**, matched to protection methods
3. **Methods:** encryption, access control, minimization, anonymization, k-anonymity, differential privacy
4. **Why anonymization fails** (re-identification cases)
5. **Choosing and comparing methods**
6. **The Privacy Report:** structure and scoring guide

Learning Objectives (SO4, PI 4c)

After this lecture you can:

- Name the main privacy laws and principles that guide data handling
- Match a **threat** to a suitable **protection method**
- Explain how encryption, access control, minimization, k-anonymity and differential privacy work
- Explain the **limits** of each method, including re-identification
- **Compare** methods and recommend one for a given system
- Write a 2 to 3 page Privacy Report that does all of the above

Why Privacy Matters

Competing interests and the rules that guide them

What Is at Stake

- **Personal data** is any information that relates to an identifiable person: name, ID numbers, location, browsing history, health records, photos
- **Harms of exposure:** identity theft, discrimination, stalking, embarrassment, loss of trust
- **Benefits of data use:** better services, medical research, public statistics, security
- Computing professionals decide **what to collect, how to store it, and who can see it**. Those choices are ethical as well as technical

Laws and Principles to Know

Source	Scope	Key ideas
GDPR (EU, 2018)	Personal data of people in the EU	Seven principles in Article 5: lawfulness, fairness and transparency; purpose limitation; data minimization; accuracy; storage limitation; integrity and confidentiality; accountability
CCPA / CPRA (California)	Consumer data held by covered businesses	Rights to know what is collected, delete it, and opt out of its sale or sharing
HIPAA (U.S.)	Health information held by covered entities	Privacy and security rules for protected health information
FERPA (U.S.)	Student education records	Limits disclosure of records without consent

Teaching summaries of public sources (GDPR text; state and federal agency pages)

Threats and Methods

Pick the tool that fits the threat

Threat to Method Map

Threat	Example	Main protection method
Eavesdropping on data in transit	Reading traffic on public Wi-Fi	**Encryption in transit** (TLS)
Stolen disk or database dump	Lost laptop, leaked backup	**Encryption at rest**
Staff or software seeing too much	Support agent browsing all records	**Access control**: least privilege, roles, logging
Holding more data than needed	Storing birthdates just to send newsletters	**Data minimization** and retention limits
Sharing a dataset for research	Hospital releases patient records	**Anonymization**, k-anonymity
Publishing statistics from sensitive data	Census tables, usage analytics	**Differential privacy**

Encryption

Symmetric

- One shared secret key encrypts and decrypts
- Fast: good for bulk data and disks
- Problem: how to share the key safely

Public key

- Public key encrypts; only the private key decrypts
- Solves key sharing; slower
- Used to set up secure connections and sign data

Where it applies

- **At rest:** disks, databases, backups
- **In transit:** TLS between app and server
- Limit: authorized users and the app itself still see plaintext

Encryption protects against outsiders who obtain the data, not against misuse by those who hold the key.

Access Control and Minimization

- **Authentication:** prove who you are (passwords, multi-factor)
- **Authorization:** decide what you may do. **Role-based access control (RBAC)** grants permissions by role
- **Least privilege:** give each person and program only the access the job needs
- **Audit logs:** record who accessed what, so misuse can be detected
- **Data minimization:** collect only what the stated purpose needs; delete it when the purpose ends. Data you never collected cannot leak
- Limit: insiders with legitimate access can still misuse data

Anonymization and Its Limits

Removing names is not enough

Anonymization and Pseudonymization

- **Anonymization:** change data so people can no longer be identified, by anyone, using reasonably available means
- **Pseudonymization:** replace identifiers with codes (user 4417749). The mapping may exist elsewhere, so this is **reversible** and the data is still personal data under GDPR
- Typical first step: delete direct identifiers (name, SSN, e-mail)
- Hidden risk: **quasi-identifiers** such as ZIP code, birth date, gender and age can be combined to single out a person

Re-identification: Three Famous Cases

Massachusetts health records

- Records had names removed
- Latanya Sweeney matched ZIP, birth date and gender with a voter list and found the governor's record
- She later estimated that 87% of the U.S. population is unique on those three fields

AOL search logs (2006)

- AOL released 3 months of searches with user numbers
- Reporters identified one user from her searches alone
- AOL withdrew the data

Netflix Prize (2006)

- Ratings released with names removed
- Researchers matched them to public IMDb reviews and identified some users
- Prize sequel was cancelled

Lesson: unique combinations of ordinary facts identify people. Summaries from public reporting and papers.

k-Anonymity: Worked Example

	Original: ZIP	Age	Condition	Released: ZIP	Age	Group
1	13053	28	Heart disease	130xx	under 30	A
2	13068	29	Heart disease	130xx	under 30	A
3	13068	21	Viral infection	130xx	under 30	A
4	13053	23	Viral infection	130xx	under 30	A
5	14853	50	Cancer	1485x	40 and over	B
6	14853	55	Heart disease	1485x	40 and over	B
7	14850	47	Viral infection	1485x	40 and over	B
8	14850	49	Viral infection	1485x	40 and over	B

Each combination of released ZIP and age appears **4 times**, so the table is **4-anonymous**: an attacker who knows a person's ZIP and age cannot narrow the record below 4 candidates.

What k-Anonymity Does and Does Not Do

- **Idea:** generalize quasi-identifiers (ZIP to a prefix, age to a range) until every combination is shared by at least **k** records
- **Trade-off:** larger k means more privacy but less detail, so the data is less useful
- **Weakness 1, homogeneity:** if all k records in a group share the same condition, the attacker learns it anyway
- **Weakness 2, background knowledge:** an attacker who knows a person is in group A and does not have the flu can narrow the possibilities
- **Weakness 3, linking:** combining several releases can break the guarantee
- Extensions such as l-diversity address some of these weaknesses

Differential Privacy

Idea

- The answer to a query should be almost the same whether or not **any one person** is in the data
- Achieved by adding calibrated random **noise**

The parameter ε

- Small ε: more noise, **stronger privacy**, less accuracy
- Large ε: less noise, weaker privacy
- Example: a count (change by at most 1) with Laplace noise of scale 1/ε

In practice

- Used by the U.S. Census Bureau for the 2020 Census, and by large technology companies for usage statistics
- Cost: noise hurts small groups most; repeated queries use up a privacy budget

Randomized Response Intuition

Step	What happens
1	Each person flips a coin. **Heads:** answer truthfully. **Tails:** flip again and answer yes if heads, no if tails
2	No one can tell whether an individual answer was true, so each person has deniability
3	P(says yes) = 0.5 × p + 0.25, where p is the true fraction of yes
4	Solve for p: p = 2 × (observed − 0.25)
Example	If 40% say yes: p = 2 × (0.40 − 0.25) = **0.30**, i.e. about 30% truly yes

The group statistic stays accurate while each individual is protected. More noise gives more privacy and less accuracy.

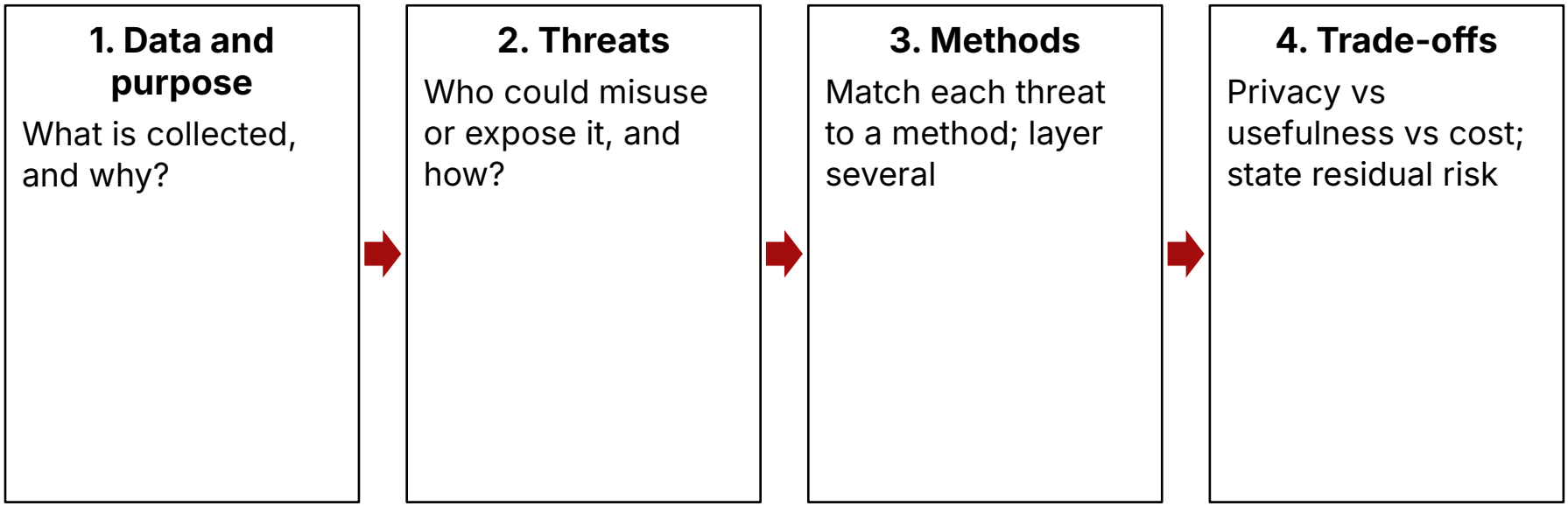
Choosing Methods

Compare, then recommend

Comparing the Methods

Method	Protects against	Strength	Limit
Encryption	Outsiders with stolen or intercepted data	Strong mathematical protection	Does not stop misuse by key holders
Access control	Unauthorized or excessive access	Simple, enforceable, auditable	Insiders with legitimate access
Minimization	Breach and misuse of unneeded data	Removes the risk at the source	Needs a clear purpose; may reduce features
Pseudonymization	Casual exposure	Easy; keeps data linkable by owner	Reversible; still personal data
k-anonymity	Linking quasi-identifiers	Easy to explain and check	Homogeneity and background knowledge
Differential privacy	Inference from published statistics	Provable guarantee	Noise cost; hard to tune

How to Choose: A Decision Process



Real systems layer methods: encrypt, restrict access, collect less, and publish only protected statistics.

The Privacy Report

Structure and scoring guide

Privacy Report Structure (2 to 3 pages)

Part	Content	About
1. System and data	What the system does, what personal data it uses, who the users are	Half a page
2. Privacy risks	Two or three concrete threats, with a harmed party for each	Half a page
3. Methods	Two or more methods: how each works and how it addresses a threat. Include one limit of each	One page
4. Comparison and recommendation	Compare the methods (strengths, limits, cost) and recommend a combination	Half a page
5. References	At least three credible sources, cited in a consistent style	A few lines

Check the syllabus for the due date and format.

What Strong Work Looks Like (4c)

Level	Description
4 Exemplary	Describes several methods correctly with real detail, explains limits, compares them against each other, and recommends a justified combination
3 Proficient	Describes at least two methods correctly with some detail and mentions limits or trade-offs
2 Developing	Names methods but explanation is thin or partly wrong; no comparison
1 Beginning	Vague or incorrect: says 'encrypt it' with no explanation

Descriptors summarize the scale used for the course SO4 assessment. Confirm the wording with the department rubric.

Common Mistakes to Avoid

- Treating **anonymization** as simply deleting names
- Saying a method makes data **'completely safe'**: every method has limits
- Naming methods without explaining **how they work**
- Listing methods with no **comparison** or reasoned choice
- Ignoring **usefulness**: perfect privacy that destroys the data is not a solution
- No **references**, or references that are not credible

Summary

- Match **threats** to **methods**; no single method covers everything
- **Encryption** guards against outsiders; **access control** and **minimization** guard against over-collection and over-access
- **Anonymization** fails when quasi-identifiers can be linked: Sweeney, AOL, Netflix
- **k-anonymity** is simple but has known weaknesses; **differential privacy** gives a provable guarantee at a cost in accuracy
- Strong reports **explain, compare and recommend**

References

- GDPR, Regulation (EU) 2016/679, Article 5 (principles). gdpr-info.eu/art-5-gdpr/
- L. Sweeney, Simple Demographics Often Identify People Uniquely (2000), Carnegie Mellon University
- Barbaro and Zeller, A Face Is Exposed for AOL Searcher No. 4417749, The New York Times (2006)
- Narayanan and Shmatikov, Robust De-anonymization of Large Sparse Datasets (2008)
- Dwork and Roth, The Algorithmic Foundations of Differential Privacy (2014)
- U.S. Census Bureau, Differential privacy and the 2020 Census. census.gov
- California Attorney General, CCPA overview. oag.ca.gov/privacy/ccpa
- Original teaching summaries, not legal advice.